Seguridad en Base de Datos

- Introducción a la Seguridad y Matriz de Autorización
- Control de Acceso Discrecional (DAC) y Roles (RBAC)
- Nivel de Vistas y Abstracción de Datos

Si un atacante logra vulnerar el servidor web o inyectar código en una aplicación que se conecta a la base de datos utilizando el usuario root (o admin), ¿qué tan grave es el impacto y qué control de daños nos queda?

Los datos guardados en la base de datos deben estar protegidos contra los accesos no autorizados, de la destrucción o alteración malintencionadas además de la introducción accidental de inconsistencias que evitan las restricciones de integridad.

Violaciones de la seguridad

Entre las formas de acceso malintencionado se encuentran:

- La lectura no autorizada de los datos (robo de información)
- La modificación no autorizada de los datos
- La destrucción no autorizada de los datos

Violaciones de la seguridad

Entre las formas de acceso malintencionado se encuentran:

- La lectura no autorizada de los datos (robo de información)
- La modificación no autorizada de los datos
- La destrucción no autorizada de los datos

La seguridad de las bases de datos se refiere a la protección frente a accesos malintencionados.

Seguridad en Base de Datos

Autorizaciones a los datos

Los usuarios pueden tener varios tipos de autorización (todos, ninguno de ellos o una combinación determinada de los mismos.) para diferentes partes de la base de datos. Entre ellas están las siguientes:

- **La autorización de lectura (select)** permite la lectura de los datos, pero no su modificación.
- **La autorización de inserción (insert)** permite la inserción de datos nuevos, pero no la modificación delos existentes.
- **La autorización de actualización (update)** permite la modificación de los datos, pero no su borrado.
- **La autorización de borrado (delete)** permite el borrado de los datos.

Seguridad en Base de Datos

Autorizaciones al esquema

Los usuarios pueden recibir autorización para modificar el esquema de la base de datos:

- **La autorización de índices** permite la creación y borrado de índices.
- **La autorización de recursos** permite la creación de relaciones nuevas.
- **La autorización de alteración** permite el añadido o el borrado de atributos de las relaciones.
- **La autorización de eliminación** permite el borrado de relaciones (entre PK y FK)

Un usuario o aplicación solo debe poseer los derechos mínimos necesarios para cumplir su función, reduciendo drásticamente la superficie de ataque frente a un fallo o vulneración.

Control de Acceso Discrecional
(DAC - *Discretionary Access Control*)

En el modelo DAC, el propietario o administrador de un objeto de la base de datos (por ejemplo, una tabla) tiene la facultad discrecional de conceder o revocar permisos sobre dicho objeto a otros usuarios.

El lenguaje de definición de datos de SQL incluye órdenes para conceder y retirar privilegios. La instrucción grant se utiliza para conferir autorizaciones. La forma básica de esta instrucción es la siguiente:

```
GRANT <lista de privilegios> ON <nombre de base o tabla o vista>
TO <lista de usuarios>
```

```
GRANT SELECT ON sucursal
TO adeleon
```

El privilegio ***all privileges*** puede utilizarse como una forma abreviada de todos los privilegios que se pueden conceder. De manera parecida, el nombre de usuario ***public*** hace referencia a todos los usuarios presentes y futuros del sistema.

```
GRANT ALL PRIVILEGES ON sucursal TO public
```

“En una empresa se incorporan 20 analistas nuevos y 5 cambian de area en el mismo mes. Si tuviéramos que asignar o quitar permisos tabla por tabla a cada cuenta de usuario individualmente, ¿qué tan sostenible sería esa gestión y qué riesgos de seguridad se generarían?"

Control de Acceso Basado en Roles
(RBAC - *Role-Based Access Control*)

Para evitar la asignación manual e individual de privilegios ,que es propensa a errores y difícil de auditar, la norma SQL contempla la creación de Roles.

- Abstracción mediante Roles: Un rol es un conjunto conglutinado de privilegios que representa una función dentro de la organización (ej. rol_ventas, rol_auditor).
- Asignación: Los privilegios se otorgan al rol, y los usuarios son asignados como miembros de dicho rol.

Ventajas claves:

- Administración simplificada: Al cambiar las responsabilidades de una persona, solo se le cambia de rol.
- Principio de menor privilegio: Es más fácil verificar qué permisos tiene un rol específico que revisar la matriz de usuarios individuales.
- Jerarquía de roles: Un rol puede heredar los privilegios de otro rol (ej. rol_gerente hereda todos los permisos de rol_empleado).

Roles

1. Crear un rol para el equipo de análisis de datos

```
CREATE ROLE IF NOT EXISTS 'rol_analista_datos';
```

2. Otorgar permisos de consulta e inserción sobre una tabla específica al rol en sakila

```
GRANT SELECT, INSERT ON  <basededatos.tabla> TO 'rol_analista_datos';
```

3. Crear una cuenta de usuario para un analista

```
CREATE USER IF NOT EXISTS 'nombre'@'localhost' IDENTIFIED BY 'ClaveSegura2026!';
```

4. Asignar el rol al usuario

```
GRANT 'rol_analista_datos' TO 'nombre'@'localhost' ;
```

5. Definir el rol como activo por defecto al iniciar sesión

```
SET DEFAULT ROLE 'rol_analista_datos' TO 'nombre'@'localhost' ;
```

6. Comprobar los privilegios del rol y del usuario

```
SHOW GRANTS FOR 'rol_analista_datos';
SHOW GRANTS FOR ‘nombre'@'localhost';
```

Quitar Permisos

REVOKE <lista de privilegios> **ON** <nombre de relación o de vista> **FROM** <lista de usuarios o papeles>

REVOKE SELECT ON sucursal **FROM** U1, U2, U3
REVOKE UDATE (importe) **ON** prestamo from U1, U2, U3

"Imaginemos que el equipo de Recursos Humanos necesita que los líderes de equipo vean a sus empleados para asignar proyectos, pero sin ver los sueldos ni los números de cuenta bancaria. ¿Cómo le otorgamos acceso a la tabla empleados a un usuario si el permiso GRANT SELECT te da acceso a **toda** la tabla?"

Vistas y Abstracción de Datos

En el modelo relacional, los permisos estándar (GRANT SELECT) operan sobre relaciones completas. Para lograr **seguridad granular** (restringir columnas o filas específicas), el texto de Silberschatz establece que se utilizan las **Vistas**:

- **Seguridad Vertical (Filtrado de Columnas):** Se crea una vista seleccionando solo las columnas no sensibles. Permite ocultar campos confidenciales (como sueldos, claves hash o números de documento).
- **Seguridad Horizontal (Filtrado de Filas o Tuplas):** Se aplica una cláusula WHERE en la vista para definir qué registros puede ver el usuario (por ejemplo, permitir que un gerente solo vea las filas de los empleados de su propio departamento).

```
REVOKE SELECT ON mi_base_de_datos.empleados FROM 'rol_analista_datos’;
GRANT SELECT ON mi_base_de_datos.vista_empleados_publica TO 'rol_analista_datos';
```